



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

应对新威胁：威胁情报助力互联网应急响应

2015.9.30

SONY被黑的启示

2014年12月，在圣诞节即将到来之际，索尼公司遭遇了重大的APT攻击。上万台电脑受到影，超过100TB的数据遭到盗窃。

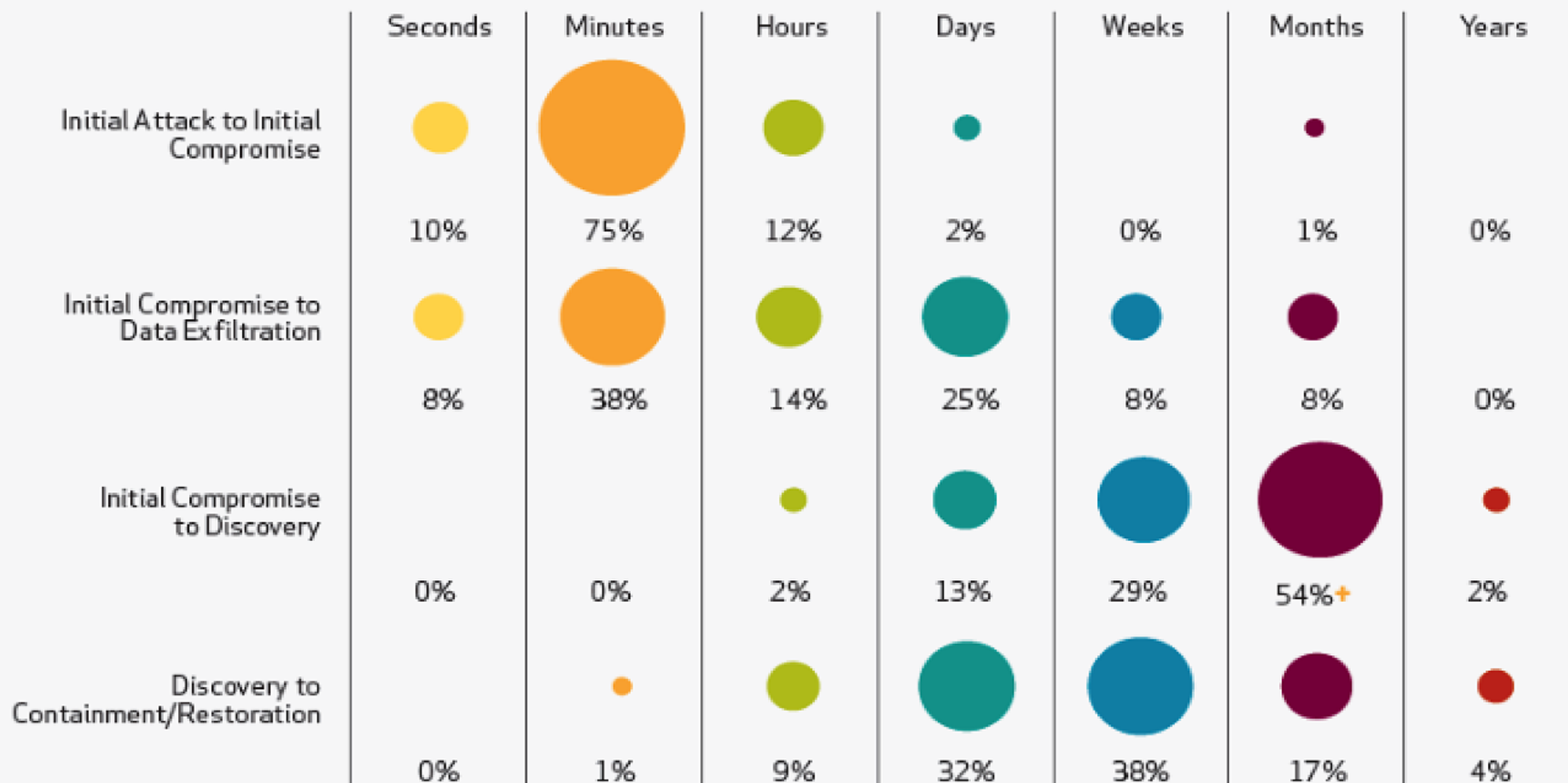
早在数个月前，黑客组织便已经开始在黑客社区谋划并实施低频攻击，而直到12月初攻击大规模发挥作用时，索尼公司才发觉自己已经被黑。

事后，FBI介入调查，可目前仍不能确认攻击者身份与定位。

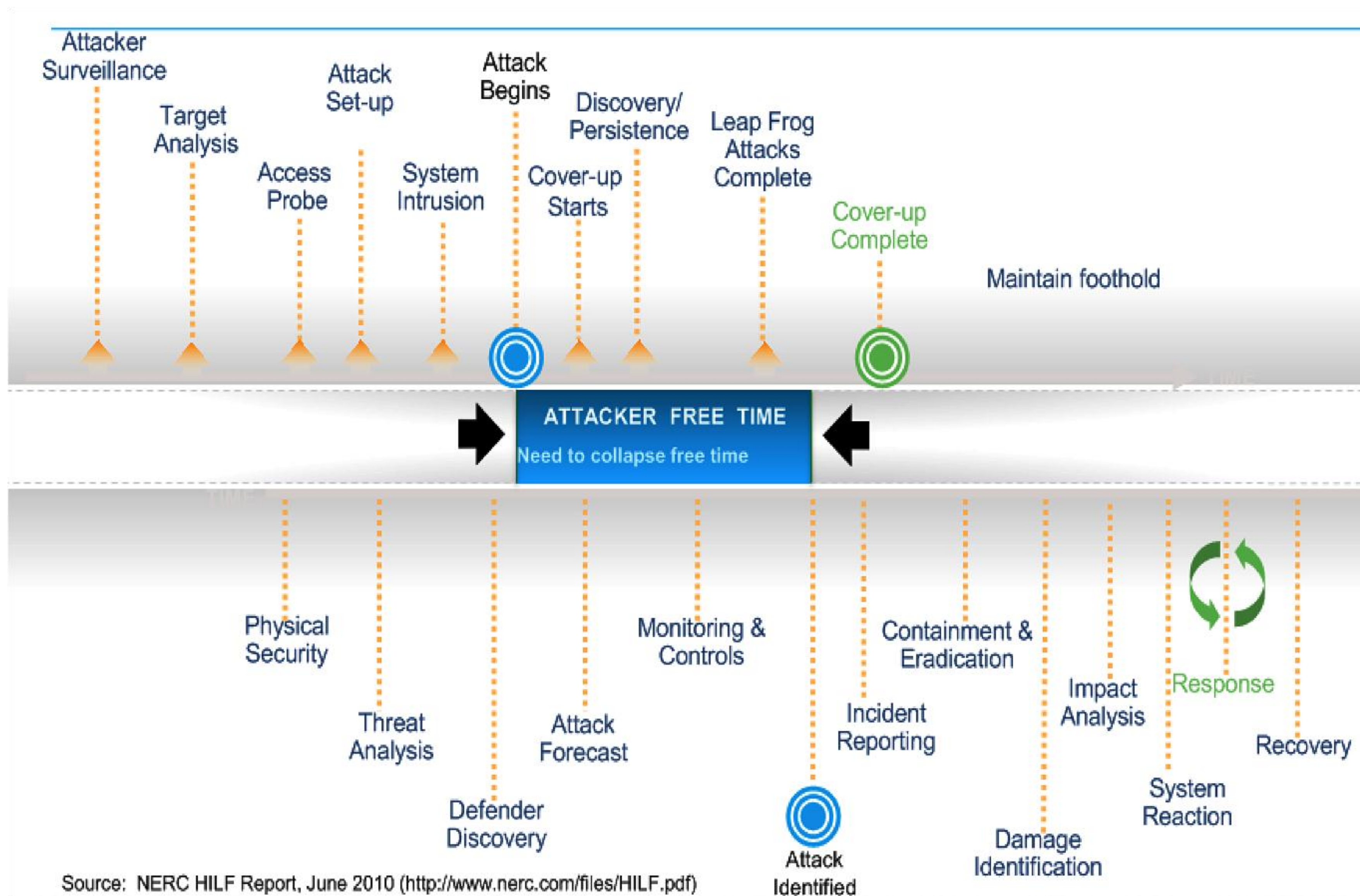


现有安全策略不足以应对新威胁

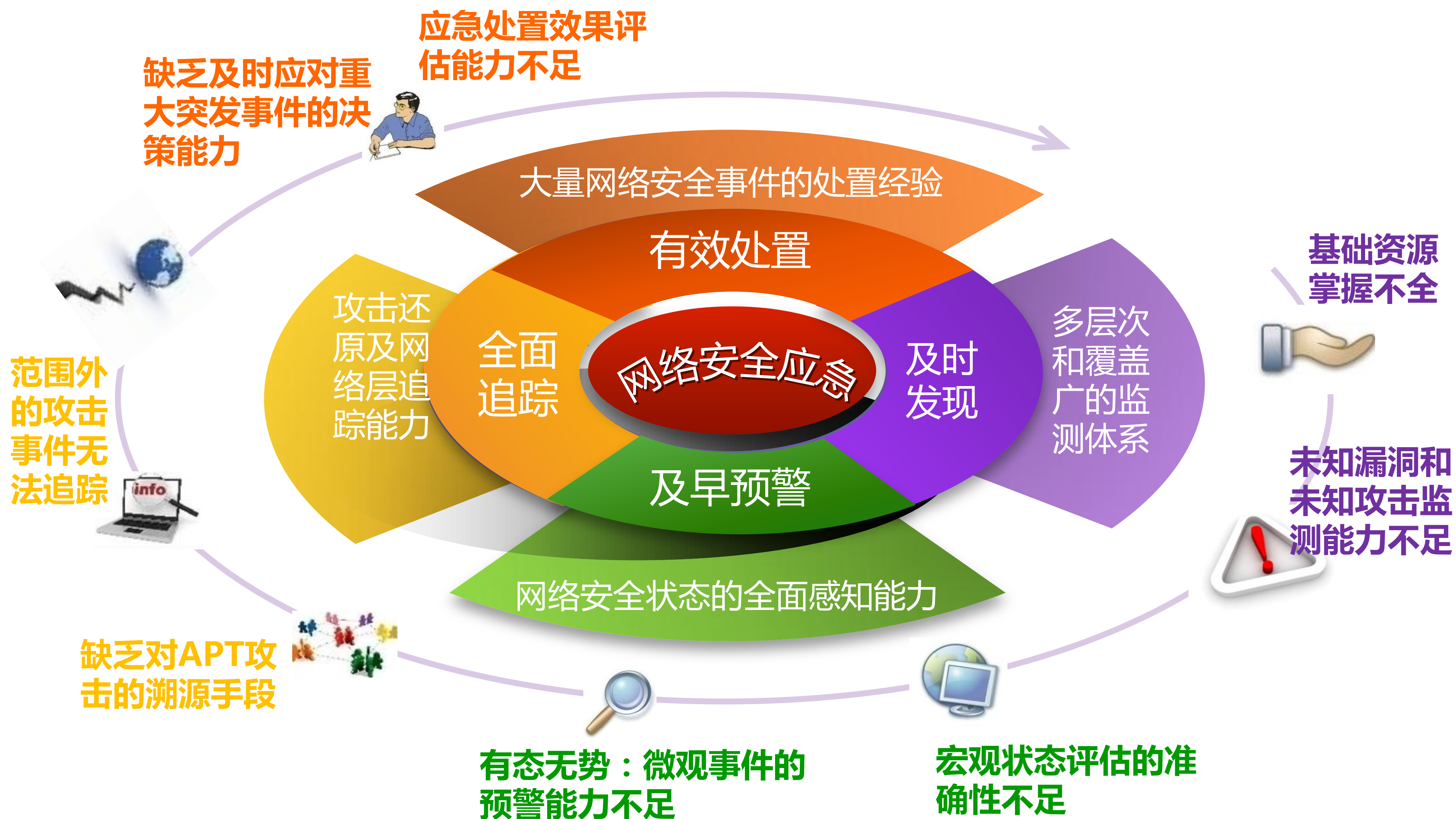
Figure 40. Timespan of events by percent of breaches



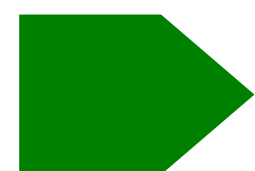
防御的关键在于发现攻击、尽早做出响应



我国网络安全应急能力的能与不足



威胁情报是解决之道



发现未知威胁，快速启动应急措施，阻断攻击



组织间协同，一经发现威胁出现，多方面联动防御

美成立网络威胁与情报整合中心



美国建立起网络与情报整合中心并以此来国土安全部、联邦调查局等多部门的威胁情报，用来应对越来越复杂的网络攻击。CTIIC将归国家情报总监办公室管，今后将是美国政府防范和应对网络威胁的主要部门、一个全国性的网络威胁情报中枢。白宫旨在加强政府各部门之间、政府与企业之间的协调，使相关机构能尽早意识到面临的网络威胁，并采取相应对策。

威胁情报定义

Gartner :

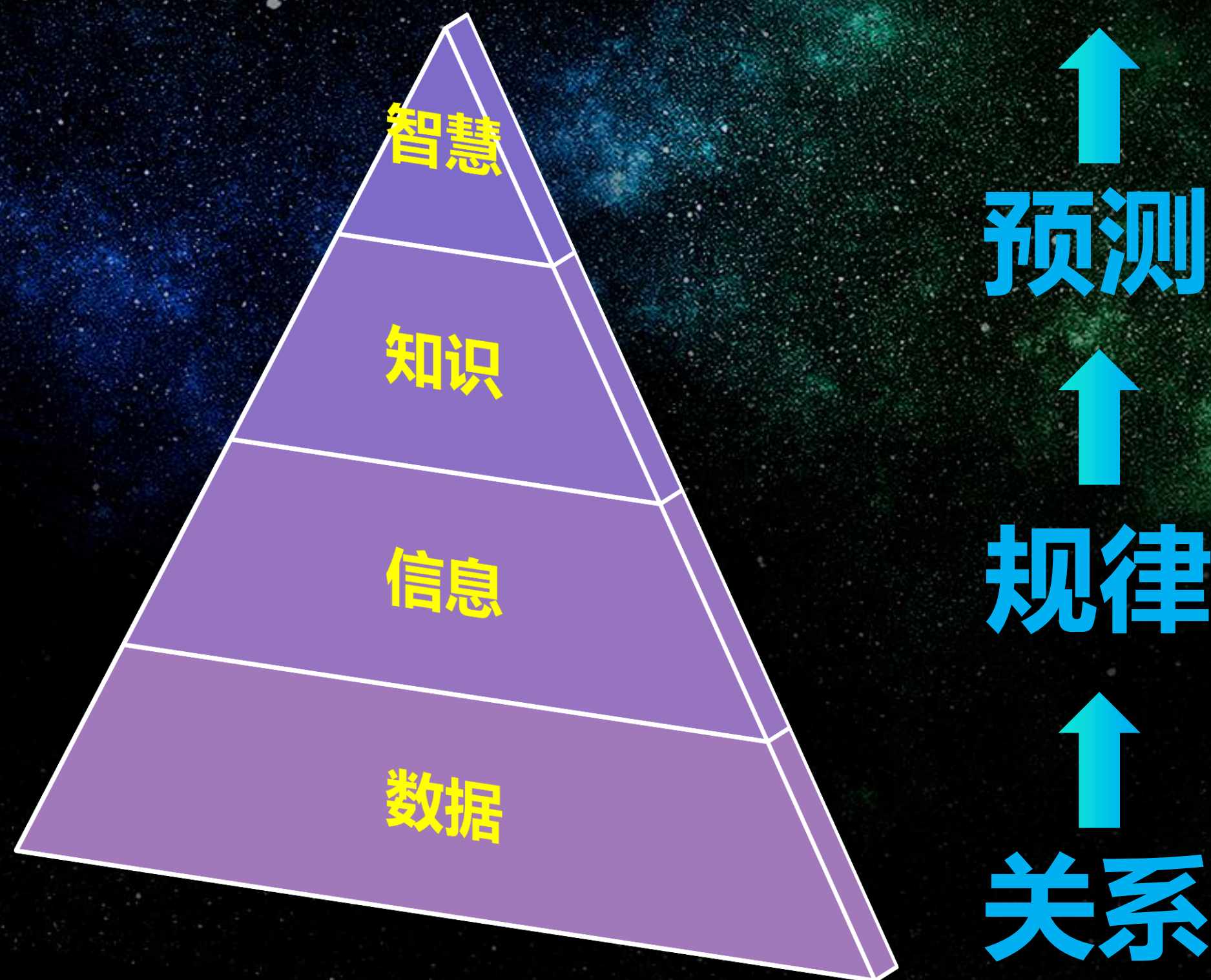
威胁情报是针对一个已经存在或正在显露的威胁或者危害资产行为的，基于证据知识的，包含情境、机制、影响和应对建议的，用于帮助解决威胁或危害决策的**知识**。

iSIGHT:

网络威胁情报是关于已经收集、分析、分发的，针对攻击者及其动机、目的手段的，用于帮助所有安全级别的业务员工用于保护其企业核心资产的**知识**。

关于知识

- 不同安全需求的问题模型、分析对象、分析方法各不相同。
- 分析员基于对数据源的理解，针对性确定分析逻辑，通过挖掘数据关系，总结规律，进而形成知识



知识的综合运用及能力，判断及预测

信息的本质、原则、经验，形成规律

数据之间的关系

客观世界和事实的描述

基于威胁情报，感应未知威胁

威胁情报

信誉情报

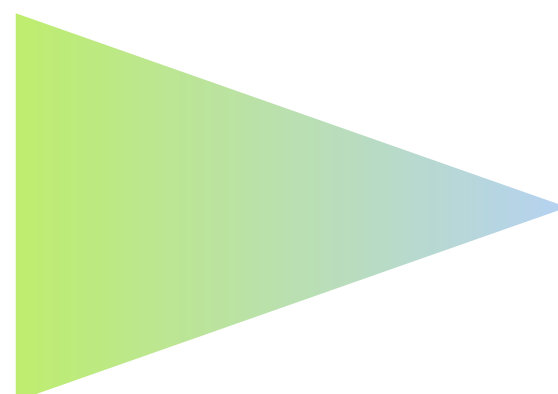
不可信或有问题的IP
地址、URL、域名、
C2服务器信息...

攻击情报

攻击源、攻击工具、
利用的漏洞、采取的
方式...

其他情报

僵尸网络地址、0day
漏洞...



情境感知

Who

低信誉或存在攻击行为
的用户

To What

是否申请访问敏感数据

When

访问时间是否异常

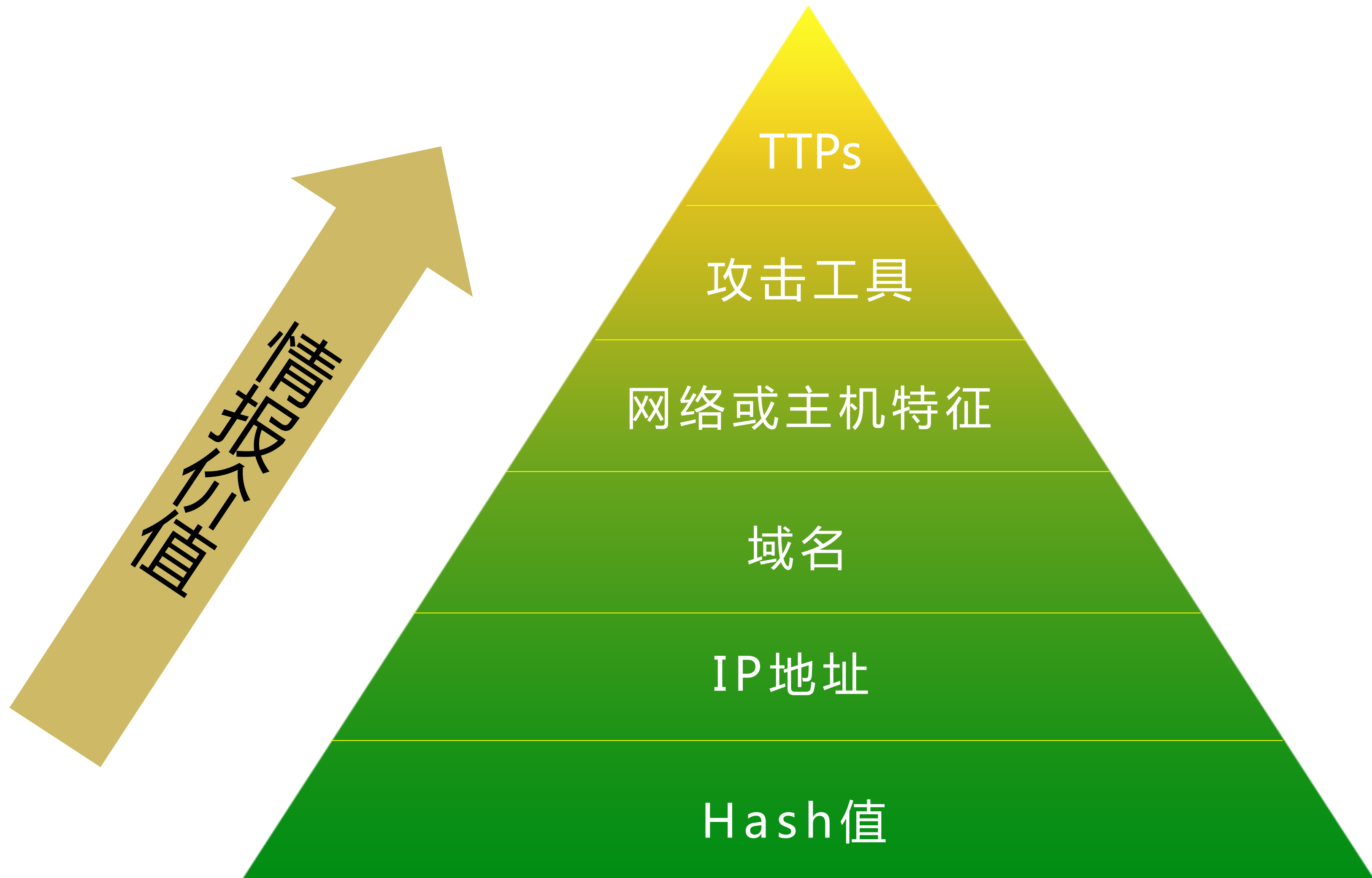
What

客户端是否存在异常

How

访问行为异常

.....



情报来源

恶意样本分析

网络数据
DNS等

产品反馈

第三方APT
信息跟踪

用户反馈

黑客组织、
社区跟踪

网络爬虫 Crowing、
漏洞信息

开源MRTI信息

威胁情报

APT事件报告

可机器读取
的IOC

情报共享信息

联动的安全管理与应急响应

SOC/SIEM

NGFW/IPS

SEG/SWG

WAF

应急响应

安全服务

大数据分析

“可行动”的情报策略

规模大结果小

变化快进化慢

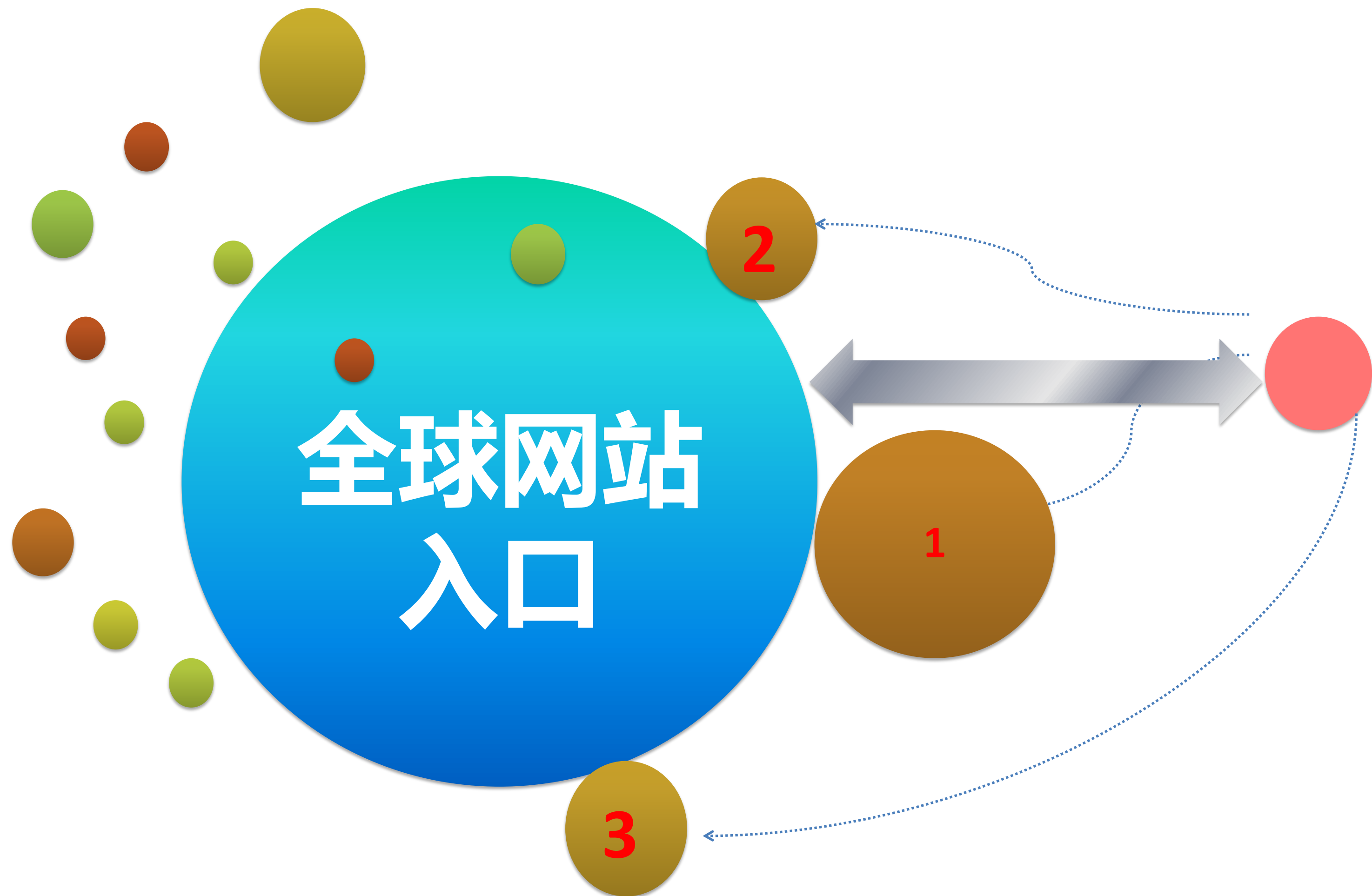
种类多关联少

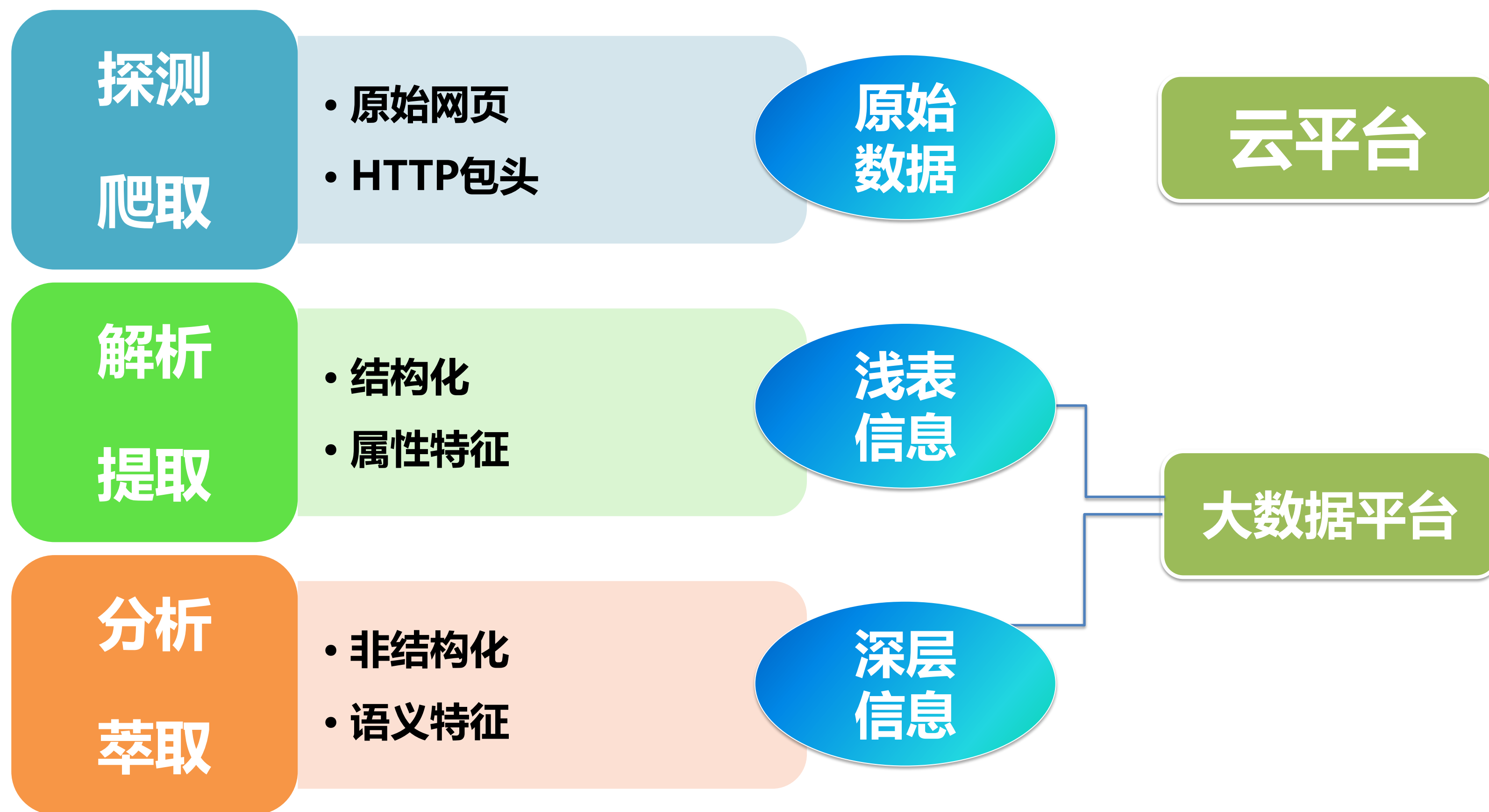
从十亿个网站入手的相似性发现



真假银行网站







基于被动域名监测的基础数据



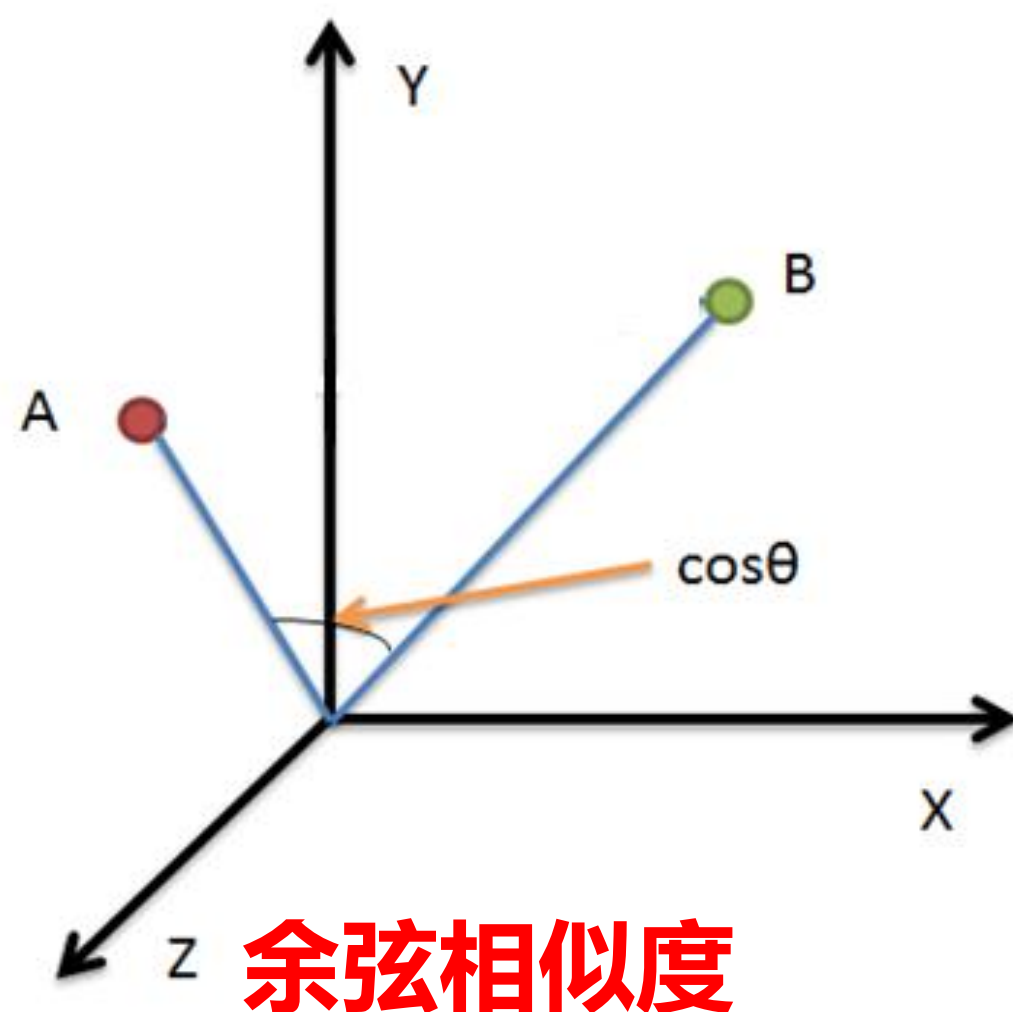
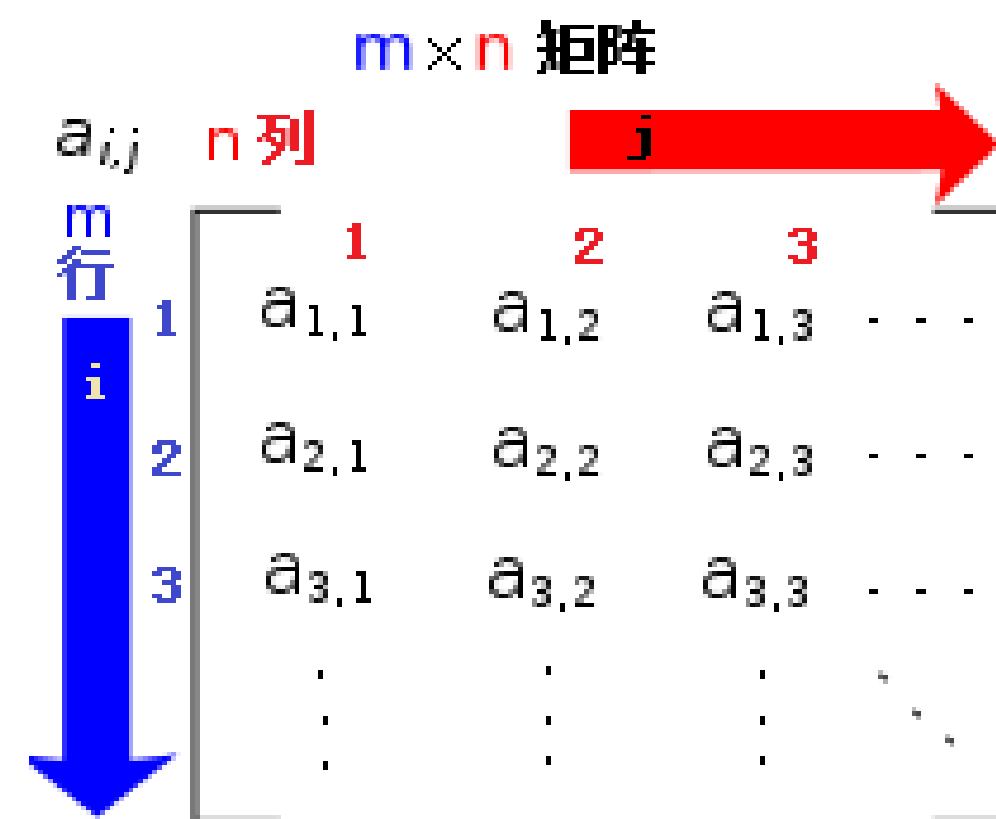
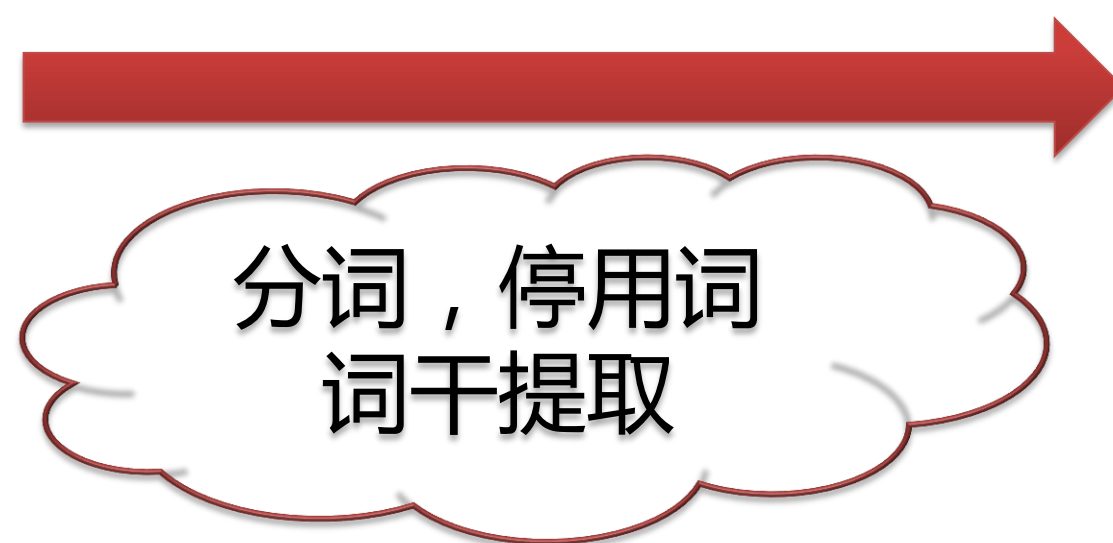
全球网站基础信息采集

十亿域名

工行首页	http://www.icbc.com.cn/icbc/
META CONTENT	META name="Keywords" content="网上基金、网上股票、网上贵金属、网上黄金、网上理财、网上保险、网上外汇、网上期货、网上债券、专家述评、财经动态、电子银行、网上银行、电话银行、手机银行、 网上缴费、网上捐款、个人金融、银行卡、公司业务、机构业务、资产托管、企业年金、投资银行、资产处置、网上商城、工行学苑、原创舞台、E动天地、金融咨询、焦点关注、网上论坛、工行风貌、工行快讯、媒体看工行、金融信息、重要公告、优惠活动、客户服务、金融超市"> <META name="Description" content="工商银行金融服务全面介绍，投资理财信息丰富全面，在线交易方便快捷，满足客户专业化、多元化、人性化的金融服务需求，打造集业务、信息、交易、购物、互动于一体综合性金融服务平台。">
option title	<option title=' 个人贷款' value=' /ICBC/个人金融/个人服务/个人贷款/' >个人贷款</option> <option title=' 投资理财' value=' /ICBC/个人金融/个人服务/投资理财/' >投资理财</option> <option title=' 便利金融' value=' /ICBC/个人金融/个人服务/便利金融/' >便利金融</option> <option title=' 跨境金融' value=' /ICBC/个人金融/个人服务/跨境金融/' >跨境金融</option> <option title=' 存款服务' value=' /ICBC/个人金融/个人服务/存款服务/' >存款服务</option> <option title=' 银行卡服务' value=' /ICBC/个人金融/个人服务/银行卡服务/' >银行卡服务</option> <option title=' 电子银行服务' value=' /ICBC/个人金融/个人服务/电子银行服务/' >电子银行服务</option>



TF-IDF



从三维到M维



M: 词库规模

(**几十万** 量级)

N: 文档规模

(**上亿** 数量级)

计算得分 网站相似度排名TOP20

100	http://www.icbc.com.cn
99.99	http://pdx.qsxg.info/gs/gspay/?/ite.tao.com/itm.htm?id=4345123
99.98	http://www.95588mzk.com/display.php
99.97	http://tianmaxingko.ip8.jspcn.net/
99.96	http://rtfg5.tk/BocnetClient/PreLoginPGW.do/
99.95	http://oiks6.myfw.us/icbc.asp?num=051027-19200786048&money=1.00
99.94	http://www.stenyice.tk/gdfz3.asp
99.93	http://www.stenyice.tk/ipperform013.asp
99.92	http://www.desrfiem.tk/gdfz3.asp
99.91	http://www.desrfiem.tk/ipperform013.asp
99.9	http://www.winashine.tk/icbc.asp?num=051027-19200786048&money=1.00
99.89	http://www.winashine.tk/gdfz3.asp
99.88	http://www.vsb61ce.de.pn/icbc.asp?num=051027-19200786048&money=1.00
99.87	http://www.n4587.com/icbc2.asp
99.86	http://www.liubi.tk/a_b1.php?type=up.hmx
99.85	http://www.h3154.com/icbc2.asp
99.84	http://www.whxx168.com/reg_2xx0.asp
99.83	http://www.d8865.com/icbc2.asp
99.82	http://199.115.96.196/pay/gong/4.asp?id=335&code=4652799991&money=1.00&orderid=201422100000000000004315324634&num=1%20
99.81	http://www.jy1088pt.com/icbc2.asp

构建威胁情报生态系统



情报来源

政府机构

防病毒厂家

Anti—APT厂家

检测类产品厂家

漏洞播报平台

专业情报厂家

情报产生

政府机构

专业情报厂家

情报应用

政府机构

安全产品厂家

云安全服务厂家

企业用户



Thanks